

对 BLP 模型进行了扩充，它将用户和资源进行分类，并允许它们之间交换信息，这是多边安全体系的基础。在执行访问控制功能时，Lattice 模型本质上与 BLP 模型是相同的，而 Lattice 模型更注重形成“安全集束”。BLP 模型中的上读和下写原则在此仍然适用，但前提条件必须是各对象位于相同的安全集束中。主体和客体位于不同的安全集束时，不具有可比性，它们之间没有信息可以流通。

3. Biba 模型

Biba 访问控制模型对数据提供了分级别的完整性保证，类似于 BLP 保密性模型，Biba 模型也使用 MAC 系统。BLP 模型只解决了信息的保密问题，它在完整性定义方面仍存在一定缺陷。BLP 模型没有采取有效的措施来制约对信息的非授权修改，因此使非法和越权篡改成为可能。考虑到上述因素，Biba 模型模仿 BLP 模型的信息保密性级别，定义了信息完整性级别，在信息流向的定义方面不允许从级别低的进程流向级别高的进程，也就是说，用户只能向比自己安全级别低的客体写入信息，从而防止非法用户创建安全级别高的客体信息，避免越权和篡改等行为的发生。Biba 模型可同时针对有层次的安全级别和无层次的安全种类。

Biba 模型基于两种规则来保障数据的完整性与保密性，分别是下读和上写。下读是指主体不能读取安全级别低于它的数据，上写是指主体不能写入安全级别高于它的数据。从这两个属性来看，Biba 模型与 BLP 模型的两个属性是相反的，BLP 模型提供保密性，而 Biba 模型对于数据的完整性提供保障。

9.4.3 访问控制分类

访问控制最早产生于 20 世纪 60 年代，随后出现了多种重要的访问控制机制。访问控制因实现的基本理念不同，分类也不同。常见的访问控制机制主要有自主访问控制（Discretionary Access Control, DAC）、强制访问控制、基于角色的访问控制（Role-Based Access Control, RBAC）、基于任务的访问控制（Task-Based Access Control, TBAC）和基于对象的访问控制（Object-Based Access Control, OBAC）等。

1. 自主访问控制

自主访问控制是目前计算机系统中实现最多的访问控制机制，它是在确认主体身份以及它们所属组的基础上，对访问进行限定的一种方法。传统的 DAC 最早出现在 20 世纪 70 年代初期的分时系统中，它是多用户环境下最常用的一种访问控制技术，在 UNIX 类操作系统中普遍采用。其基本思想是，允许某个主体显式地指定其他主体对该主体所拥有的资源是否可以访问，以及可执行的访问类型。

2. 强制访问控制

MAC 最早出现在 Multics 系统中，在可信计算机系统评估标准（Trusted Computer System Evaluation Criteria, TCSEC）中被用作 B 级安全系统的主要评价标准之一。MAC 的基本思想是，每个主体都有既定的安全属性，每个客体也都有既定的安全属性，主体对客体是否能执行特定的操作取决于两者安全属性之间的关系。通常，MAC 都要求主体对客体的访问满足 BLP 模型

的两个基本特性。

在实现上，MAC 和 DAC 通常为每个用户赋予对客体的访问权限规则集，考虑到管理的方便，在这一过程中，还经常将具有相同职能的用户聚为组，然后再为每个组分配许可权。用户自主地将自己所拥有的客体的访问权限授予其他用户的这种做法，其优点是显而易见的，但是，当企业的组织结构或系统的安全需求处于变化的过程中时，就需要进行大量烦琐的授权变动，系统管理员的工作将变得非常繁重，容易发生错误造成一些意想不到的安全漏洞。考虑到上述因素，必然会产生新的机制加以解决。

3. 基于角色的访问控制

基于角色的访问控制技术由于其对角色和层次化管理的引进，特别适用于用户数量庞大、系统功能不断扩展的大型系统。在 RBAC 中，在用户和访问许可权之间引入了角色的概念，用户与特定的一个或多个角色相联系，角色与一个或多个访问许可权相联系。

迄今为止，已发展了 4 种 RBAC 模型，其中基本模型（RBAC0）指明了用户、角色、访问权和会话之间的关系；层次模型（RBAC1）是偏序的，上层角色可继承下层角色的访问权；约束模型（RBAC2）除包含 RBAC0 的所有基本特性外，还增加了对 RBAC0 的所有元素的约束检查，只有拥有有效值的元素才可被接受；层次约束模型（RBAC3）兼有 RBAC1 和 RBAC2 的特点。

与 DAC 和 MAC 相比，RBAC 具有明显的优越性，RBAC 基于策略无关的特性，使它几乎可以描述任何安全策略，甚至 DAC 和 MAC 也可以用 RBAC 来描述。相比较而言，RBAC 是实施面向企业的安全策略的一种有效的访问控制方式，具有灵活性、方便性和安全性等特点，目前在大型 DBMS 的权限管理中得到普遍应用。

4. 基于任务的访问控制

基于任务的访问控制从应用和企业层角度来解决安全问题。它采用面向任务的观点，从任务的角度来建立安全模型和实现安全机制，在任务处理的过程中提供动态实时的安全管理。在 TBAC 中，对象的访问权限控制并不是静止不变的，而是随着执行任务的上下文环境发生变化，因此，TBAC 是一种动态安全模型。

TBAC 模型由 workflow、授权结构体、授权步和许可集 4 个部分组成。一个 workflow 的业务流程由多个任务构成，而一个任务对应于一个授权结构体，每个授权结构体由特定的授权步组成。授权结构体之间和授权步之间通过依赖关系联系在一起。在 TBAC 中，一个授权步的处理可以决定后续授权步对处理对象的操作许可。

通过授权步的动态权限管理，TBAC 支持最小特权原则和最小泄露原则，在执行任务时只给用户分配所需的权限，未执行任务或任务终止后用户不再拥有所分配的权限；在执行任务过程中，当某一权限不再使用时，授权步自动将该权限回收。TBAC 适用于 workflow、分布式处理、多点访问控制的信息处理和事务管理系统，最显著的应用是在安全 workflow 管理系统中。

5. 基于对象的访问控制

控制策略和控制规则是基于对象的访问控制的核心，在 OBAC 模型中，将 ACL 与受控对象及其属性相关联，并将访问控制选项设计成为用户、组或角色及其对应权限的集合。同时，

允许对策略和规则进行复用、继承和派生操作。这样，不仅可以对受控对象本身进行访问控制，受控对象的属性也可以进行访问控制，而且派生对象可以继承父对象的访问控制设置，这对于信息量巨大、信息内容更新变化频繁的管理信息系统非常有益，可以减轻由于信息资源的派生、演化和重组等带来的分配和设定角色权限等的工作量。

9.5 容灾与业务持续

灾难是指由于人为或自然的原因，造成信息系统严重故障或瘫痪，使信息系统支持的业务功能停顿或服务水平不可接受、达到特定的时间的突发性事件。当应用系统的一个完整环境因灾难性事件遭到破坏时，为了迅速恢复应用系统的数据和环境，使应用系统恢复运行，需要异地灾难备份系统，也称为容灾系统。

灾难备份是指为了灾难恢复而对数据、数据处理系统、网络系统、基础设施、技术支持能力和运行管理能力进行备份的过程。灾难备份与普通的数据备份的不同在于，它不仅备份系统中的数据，还备份系统中安装的应用程序、数据库系统、用户设置、系统参数等信息，以便在需要时迅速恢复整个系统。

9.5.1 灾难恢复技术

灾难恢复是指为了将信息系统从灾难造成的故障或瘫痪状态恢复到可正常运行状态，并将其支持的业务功能从灾难造成的不正常状态恢复到可接受状态，而设计的活动和流程。灾难恢复措施在整个备份制度中占有相当重要的地位。因为它关系到系统在经历灾难后能否迅速恢复。

1. 灾难恢复的技术指标

发生灾难时，对恢复工作所需的时间有一个清楚的认识是至关重要的，同样，了解现在的数据在恢复之后是什么样子的也同等重要。并非所有应用和数据都需要相同级别的可用性，灾难恢复的指标主要与容灾系统的数据恢复能力有关。

灾难恢复的两个关键概念是恢复点目标（Recovery Point Objective, RPO）和恢复时间目标（Recovery Time Objective, RTO）。RPO 是指灾难发生后，容灾系统能将数据恢复到灾难发生前时间点的数据，它是衡量企业在灾难发生后丢失多少数据的指标；RTO 则是指灾难发生后，从系统宕机导致业务停顿时刻开始，到系统恢复至可以支持业务部门运作，业务恢复运营之时，此两点之间的时间。RPO 可简单描述为企业能容忍的最大数据丢失量，RTO 可简单描述为企业能容忍的恢复时间。

理想状态下，希望 RTO 为 0，RPO 为 0，即灾难发生对企业生产毫无影响，既不会导致生产停顿，也不会导致生产数据丢失。但这显然不现实，企业要做的是尽量减少灾难造成的损失。企业在构建容灾备份系统时，首先要找到对企业自身而言比较适合 RTO 目标，即在该目标定义下，用于灾难备份的投入应不大于对应的业务损失。

2. 灾难恢复等级

在《信息安全技术 信息系统灾难恢复规范》（GB/T 20988—2007）中，将灾难恢复划分为